EXECUTIVE SUMMARY



Modbus Detection Lab
10/12/2026
siage

Disclaimer

The analysis, data, and reports in CSET® are provided “as is” for informational purposes only. The Cybersecurity & Infrastructure Security Agency (CISA) does not provide any warranties of any kind regarding any information contained within. In no event shall the United States Government or its contractors or subcontractors be liable for any damages, including but not limited to, direct, indirect, special, or consequential damages and including damages based on any negligence of the United States Government or its contractors or subcontractors, arising out of, resulting from, or in any way connected with this report, whether based on warranty, contract, tort, or otherwise, whether injury was sustained from, or arose out of the results of, or reliance upon the report.

CISA does not endorse any commercial product or service, including the subject of the assessment or evaluation in this report. Any reference to specific commercial products, processes, or services by trademark, manufacturer, or otherwise, does not constitute or imply its endorsement, recommendation, or favoring by CISA.

The display of the CISA official seal or other CISA visual identities on this report shall not be interpreted to provide the recipient organization authorization to use the official seal, insignia or other visual identities of CISA. The CISA seal, insignia, or other visual identities shall not be used in any manner to imply endorsement of any commercial product or activity by CISA or the United States Government. Use of the CISA seal without proper authorization violates federal law (e.g., 18 U.S.C. §§ 506, 701, 1017), and is against CISA policies governing usage of the seal.

The report is prepared and intended for internal use by the organization that made the request. The contents of this report may be subject to government or private intellectual property rights. To request distribution of this report outside the organization for which it was prepared, contact the CSET Program Office. The contents of this report may be reproduced or incorporated into other reports, but may not be modified without the prior express written permission of the CSET Program Office.

Advisory

The Cyber Security Evaluation Tool (CSET®) is only one component of the overall cybersecurity picture and should be complemented with a robust cyber security program within the organization. A self-assessment with CSET® cannot reveal all types of security weaknesses, and should not be the sole means of determining an organization's security posture.

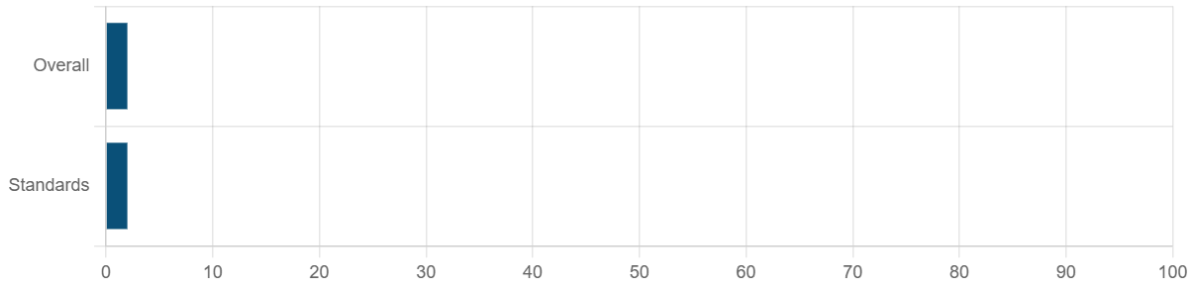
The tool will not provide a detailed architectural analysis of the network or a detailed network hardware/software configuration review. It is not a risk analysis tool so it will not generate a complex risk assessment. CSET® is not intended as a substitute for in-depth analysis of control system vulnerabilities as performed by trained professionals. Periodic onsite reviews and inspections must still be conducted using a holistic approach including facility walk-downs, interviews, and observation and examination of facility practices. Consideration should also be given to additional steps including scanning, penetration testing, and exercises on surrogate, training, or non-production systems, or systems where failures, unexpected faults, or other unexpected results will not compromise production or safety.

CSET® assessments cannot be completed effectively by any one individual. A cross-functional team consisting of representatives from operational, maintenance, information technology, business, and security areas is essential. The representatives must be subject matter experts with significant expertise in their respective areas. No one individual has the span of responsibility or knowledge to effectively answer all the questions.

Data and reports generated by the tool should be managed securely and marked, stored, and distributed in a manner appropriate to their sensitivity.

This report was prepared as an account of work sponsored by an agency of the U.S. Government. Neither the U.S. Government nor any agency thereof, nor any employee, makes any warranty, expressed or implied, or assumes any legal liability or responsibility for any third-party's use, or the results of such use, or any information, apparatus, product, or process disclosed in this publication, or represents that its use by such third party would not infringe privately owned rights.

Summary Percent Compliance

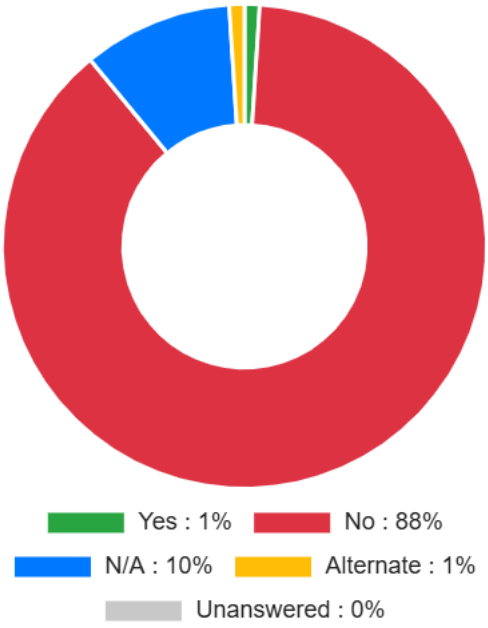


Executive Summary

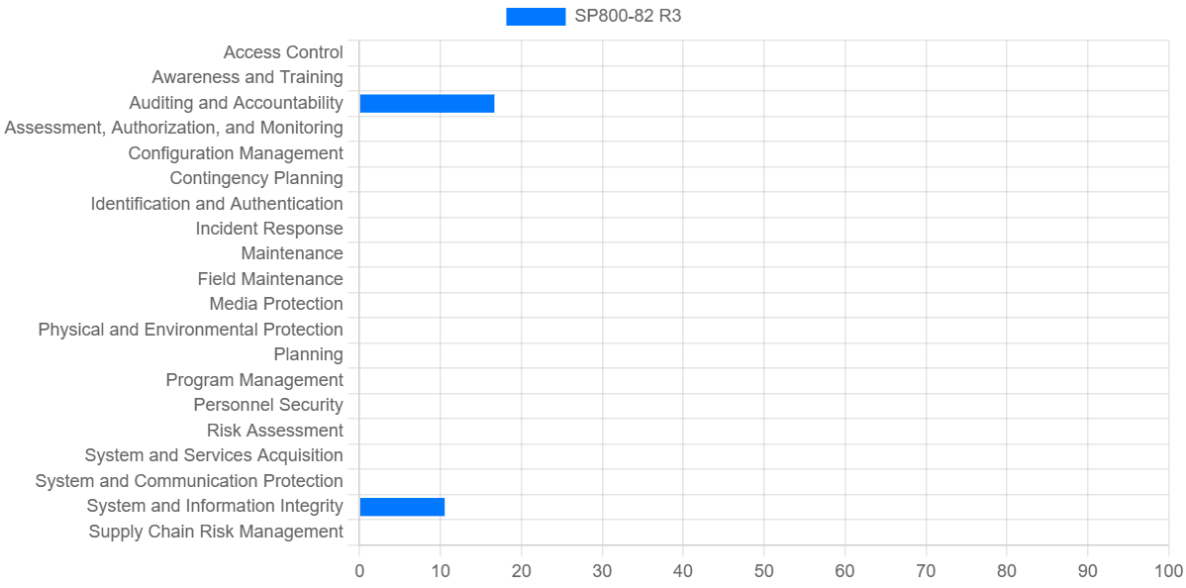
Cyber terrorism is a real and growing threat. Standards and guides have been developed, vetted, and widely accepted to assist with protection from cyber attacks. The Cyber Security Evaluation Tool (CSET) includes a selectable array of these standards for a tailored assessment of cyber vulnerabilities. Once the standards were selected and the resulting question sets answered, the CSET created a compliance summary, compiled variance statistics, ranked top areas of concern, and generated security recommendations.

Evaluation Against Selected Standards and Question Sets

Standards Summary



Standard or Question Set



Security Assurance Level (SAL)



	Confidentiality	Integrity	Availability
Overall Values	High	High	High

FIPS 199 Security Assurance Level Guidance

NIST SP800-60 (FIPS 199) Based Security Assurance Levels with CNSS Special Factors

	Confidentiality	Integrity	Availability
Adjusted For System Questions	High	High	High
Information Type	Low	Low	Low

Type	Special Factors
Confidentiality	
Integrity	
Availability	

Areas of Concern Top Subjects and Questions

The top subject areas and questions identify those areas where attention will either provide the most immediate impact or protect against the greatest vulnerabilities.

Top Categories of Concern

1. Access Control
2. Assessment, Authorization, and Monitoring
3. Auditing and Accountability
4. Awareness and Training
5. Configuration Management

Top Questions of Concern

1. OT Discussion: The policy specifically addresses the unique properties and requirements of OT and the relationship to non-OT systems. OT access by vendors and maintenance staff can occur over a large facility footprint or geographic area and into unobserved spaces, such as mechanical or electrical rooms, ceilings, floors, field substations, switch and valve vaults, and pump stations. a. Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System level*] access control policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review and update the current access control: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]. a.

Develop, document, and disseminate to [*Assignment: organization-defined personnel or roles*]: 1. [*Selection (one or more): Organization-level; Mission/business process-level; System level*] access control policy that: (a) Addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and (b) Is consistent with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines; and 2. Procedures to facilitate the implementation of the access control policy and the associated access controls; b. Designate an [*Assignment: organization-defined official*] to manage the development, documentation, and dissemination of the access control policy and procedures; and c. Review and update the current access control: 1. Policy [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*]; and 2. Procedures [*Assignment: organization-defined frequency*] and following [*Assignment: organization-defined events*].

2 OT Discussion: In OT systems, physical security, personnel security, intrusion detection, or auditing measures may support this control objective. a. Define and document the types of accounts allowed and specifically prohibited for use within the system; b. Assign account managers; c. Require [*Assignment: organization-defined prerequisites and criteria*] for group and role membership; d. Specify: 1. Authorized users of the system; 2. Group and role membership; and 3. Access authorizations (i.e., privileges) and [*Assignment: organization-defined attributes (as required)*] for each account; e. Require approvals by [*Assignment: organization-defined personnel or roles*] for requests to create accounts; f. Create, enable, modify, disable, and remove accounts in accordance with [*Assignment: organization-defined policy, procedures, prerequisites, and criteria*]; g. Monitor the use of accounts; h. Notify account managers and [*Assignment: organization-defined personnel or roles*] within: 1. [*Assignment: organization-defined time period*] when accounts are no longer required; 2. [*Assignment: organization-defined time period*] when users are terminated or transferred; and 3. [*Assignment: organization-defined time period*] when system usage or need-to-know changes for an individual; i. Authorize access to the system based on: 1. A valid access authorization; 2. Intended system usage; and 3. [*Assignment: organization-defined attributes (as required)*]; j. Review accounts for compliance with account management requirements [*Assignment: organization-defined frequency*]; k. Establish and implement a process for changing shared or group account authenticators (if deployed) when individuals are removed from the group; and l. Align account management processes with personnel termination and transfer processes.

3 OT Discussion: Close coordination occurs between OT, HR, IT, and physical security personnel to ensure the timely removal of high-risk individuals. Disable accounts of individuals within [*Assignment: organization-defined time period*] of discovery of [*Assignment: organization-defined significant risks*].

4 OT Discussion: The organization ensures that access enforcement mechanisms do not adversely impact the operational performance of the OT. Example compensating controls include encapsulation. The policy for logical access control to non-addressable and non-routable system resources and the associated information is made explicit. Access control mechanisms include hardware, firmware, and software that control the device or have device access, such as device drivers and communications controllers. Physical access control may serve as a compensating control for logical access control. However, it may not provide sufficient granularity when users require access to different functions. Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

5 OT Discussion: Information flow policy may be achieved using a combination of logical and physical flow restriction techniques. The inspection of message content may enforce information flow policy. For example, industrial OT protocols may be restricted using inbound and outbound traffic rules on a network control device between OT and IT networks. For non-routable communication, such as serial connections, devices may be configured to limit commands to and from specific tags within the OT device. The information flow policy may be supported by labeling or coloring physical connectors to aid in connecting networks. Devices that do not have a business need to communicate should not be connected (i.e., air gapped). Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on [*Assignment: organization-defined information flow control policies*].